

TechCorp Inc.

Cloud Infrastructure & DevOps Policy Guide

Version 1.4 | Effective Date: February 2025 | DevOps & Cloud Team

1. Cloud Infrastructure Overview

TechCorp uses Amazon Web Services (AWS) as its primary cloud provider, with Microsoft Azure as a secondary platform for specific enterprise workloads. All cloud infrastructure is managed via Infrastructure as Code (IaC) using Terraform. Direct console-based changes to production environments are strictly prohibited without a Change Request (CR) approval.

1.1 AWS Account Structure

- Root Account: Reserved for billing and organization management only. No workloads run here.
- Production Account (prod): Live customer-facing services. Requires P1-level change approval.
- Staging Account (staging): Pre-production testing. Mirrors production setup.
- Development Account (dev): For engineers to experiment. Costs are monitored weekly.
- Security Account: Centralized CloudTrail, GuardDuty, and Security Hub logs.

1.2 Azure Workloads

Azure is used for Microsoft 365 integrations, Azure Active Directory (AAD) as the identity provider, and Azure DevOps for certain legacy pipelines. New projects should default to AWS unless there is a specific business reason to use Azure. Azure resource provisioning requires approval from the Cloud Architecture team.

2. CI/CD Pipeline Standards

All production deployments must go through an automated CI/CD pipeline. Manual deployments to production are not allowed except during declared incidents with explicit VP Engineering approval.

2.1 Approved CI/CD Tools

- GitHub Actions: Primary CI/CD platform for all new projects.
- Jenkins: Maintained for legacy services only. No new Jenkins pipelines should be created.
- ArgoCD: Used for Kubernetes GitOps deployments in EKS clusters.
- AWS CodePipeline: Used for serverless Lambda deployments only.

2.2 Pipeline Requirements

Every CI/CD pipeline must include the following mandatory stages in order: code linting and static analysis, unit tests with minimum 80% coverage, SAST (Static Application Security Testing) using Snyk, Docker image build and scan, deployment to staging, automated integration tests, and finally production deployment with rollback capability. Any pipeline missing these stages will be blocked from merging to main.

2.3 Deployment Windows

Production deployments are permitted Monday through Thursday between 10:00 AM and 3:00 PM local time only. No deployments are allowed on Fridays, weekends, or the day before a public holiday. Emergency hotfixes require approval from the on-call engineering manager and must be followed by a post-mortem within 48 hours.

3. Kubernetes & Container Policy

3.1 Cluster Overview

TechCorp runs Kubernetes on Amazon EKS (Elastic Kubernetes Service). There are three clusters: prod-eks-us-east-1, staging-eks-us-east-1, and dev-eks-us-east-1. Cluster access is managed via AWS IAM roles and RBAC. kubectl access to production requires MFA and is logged via CloudTrail.

3.2 Container Standards

- All containers must use approved base images from TechCorp's internal ECR registry.
- Images must be scanned with Trivy before deployment. Critical and High vulnerabilities block deployment.
- Containers must not run as root. Use a non-root user in the Dockerfile.
- Resource limits (CPU and memory) are mandatory on all pods. Pods without limits will not be scheduled.
- Secrets must be injected via AWS Secrets Manager or Kubernetes Secrets — never hardcoded in images or environment variables.

3.3 Helm Chart Requirements

All Kubernetes workloads must be packaged as Helm charts stored in the internal Helm repository at helm.techcorp.internal. Chart versions must follow semantic versioning (MAJOR.MINOR.PATCH). Values files for each environment (dev, staging, prod) must be kept in separate files and committed to the application repository.

4. Monitoring & Observability

4.1 Observability Stack

- Metrics: Prometheus + Grafana. Dashboards for all production services are mandatory.

- Logs: All application logs must be shipped to the centralized ELK stack (Elasticsearch, Logstash, Kibana) at logs.techcorp.internal.
- Tracing: Distributed tracing is implemented using AWS X-Ray for Lambda and OpenTelemetry for containerized services.
- Uptime Monitoring: Pingdom is used for external endpoint monitoring. SLAs are tracked in Grafana.
- Alerting: PagerDuty is the on-call alerting platform. All P1/P2 alerts must trigger a PagerDuty incident.

4.2 SLA & SLO Requirements

All production services must define Service Level Objectives (SLOs). The minimum required SLO for customer-facing APIs is 99.9% availability (43 minutes downtime/month). Error budget policies must be defined: if a service consumes more than 50% of its monthly error budget, all new feature deployments are frozen until the budget is restored.

4.3 Log Retention Policy

Application logs are retained for 30 days in hot storage (ELK) and 1 year in cold storage (S3 Glacier). Security and audit logs are retained for 3 years in compliance with SOC 2 Type II requirements. Logs containing PII must be masked before ingestion using the log sanitization library maintained by the Security team.

5. Cloud Cost Management

5.1 Cost Allocation Tags

All AWS resources must be tagged with the following mandatory tags: Environment (prod/staging/dev), Team (e.g., backend, frontend, data), Project (Jira project key), and CostCenter (finance-assigned code). Untagged resources are automatically flagged and will be terminated after a 72-hour warning period.

5.2 Cost Optimization Rules

- Development EC2 instances must be stopped outside business hours (8 PM to 8 AM) using AWS Instance Scheduler.
- Reserved Instances or Savings Plans must be used for any workload running continuously for more than 3 months.
- S3 lifecycle policies are mandatory: move objects to Infrequent Access after 30 days, Glacier after 90 days.
- Unused Elastic IPs, idle load balancers, and unattached EBS volumes are reviewed and cleaned weekly.
- Monthly cloud spend reports are sent to team leads every first Monday of the month.

6. Cloud Access & IAM Policy

6.1 Principle of Least Privilege

All IAM roles and policies must follow the principle of least privilege — grant only the permissions required for the specific task. Wildcard permissions (e.g., '*' in IAM policies) are strictly prohibited in production accounts. IAM access reviews are conducted quarterly by the Cloud Security team.

6.2 Access Request Process

To request AWS console or CLI access, submit a Cloud Access Request via the IT Portal. Access to production accounts requires manager approval and a valid business justification. Temporary elevated access (break-glass) is available for incidents and is automatically revoked after 4 hours. All break-glass access events are reviewed by the Security team within 24 hours.

6.3 Service Account & API Keys

Long-lived IAM access keys are prohibited for human users — use SSO and role assumption instead. Service accounts must use IAM roles attached to EC2 instances or EKS service accounts, not static keys. If a static key is absolutely required, it must be stored in AWS Secrets Manager, rotated every 90 days, and approved by the Cloud Security team.

7. Disaster Recovery & Backup

7.1 RTO and RPO Targets

TechCorp defines the following recovery targets for production services: Recovery Time Objective (RTO) is 4 hours — the maximum time to restore service after an incident. Recovery Point Objective (RPO) is 1 hour — the maximum acceptable data loss window. Services that cannot meet these targets must be approved as exceptions by the CTO.

7.2 Backup Policy

- RDS databases: Automated daily snapshots retained for 35 days. Cross-region replication enabled for prod.
- S3 buckets: Versioning enabled on all production buckets. Cross-region replication for critical data buckets.
- EKS: Cluster state backed up daily using Velero to an S3 bucket in a separate AWS account.
- EC2: AMI snapshots taken weekly for stateful instances. EBS volumes snapshot daily.
- Restore drills are conducted quarterly and results are documented in Confluence.